



Smartcard = microcomputer

- I/O, S.O. e file-sytem semplificati
- Capacità di calcolo attuali
 - 3.5+ MHz
 - Data path a 32 bit, 64 bit RISC
 - RAM da 128+ KB
 - RSA con chiavi da 512+ bit
 - Comunicazione 9600+ bps
- Necessità di middleware
 - CAD (Card Acceptance Device)
- Possibile attivazione tramite PIN





Principali

■ Punti di forza

☐ **Protezione dei dati**

- *Credito corrente*
- *Password*
- *Chiavi crittografiche*

☐ Capacità di calcolo

☐ Costi contenuti

☐ Portatilità

☐ Vastità
d'applicazione

■ Applicazioni

☐ Telefonia mobile

☐ Carte di
credito/debito

☐ Pay-TV

☐ Tessere punti

☐ Autenticazione su
possessione

☐ Biometria

☐ Trasporti

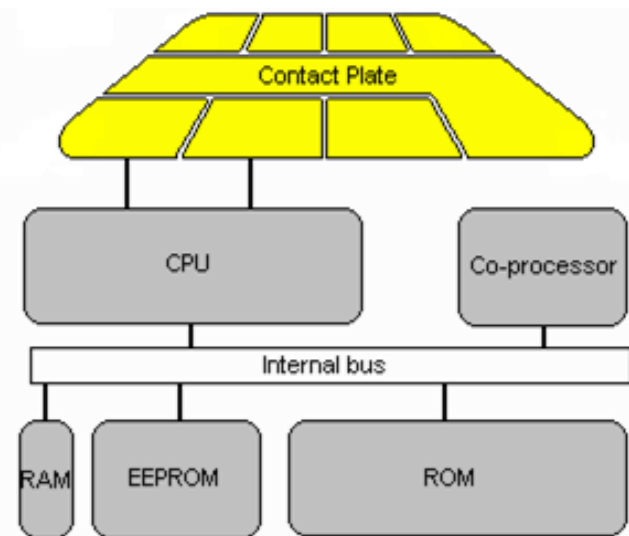
☐ Salute

☐ ...



Struttura

- Contact plate per l'I/O
- Processore e coprocessore
- ROM di 64+ KB
 - Memorizza il S.O.
- EEPROM (Electrically Erasable Programmable ROM) di 128+ KB, fa le **veci dell'H.D.**
 - Memorizza dati semi-permanenti (*SMS, #tel., ...*)
- RAM, 1+ KB
 - Memorizza dati temporanei





Sistema operativo

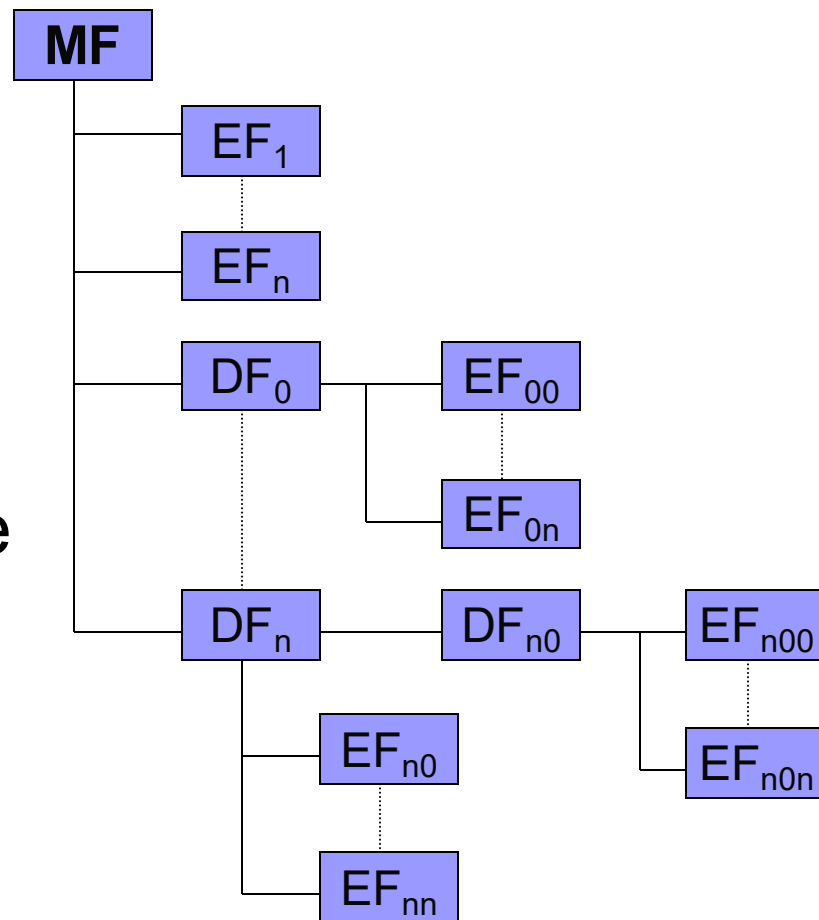
- Generalmente monofunzione
 - Di fatto rudimenti di S.O.
- Recentemente accetta installazione di nuove applicazioni
 - Un vero e proprio S.O. nel senso attuale
 - *Javacard, esecuzione di bytecode...*



File system

■ Gerarchico

- **MF** (Master File) è root del file system,
- **EF** (Elementary File) contengono i dati utente
- **DF** (Dedicated File), come le directory, contengono EF o DF
 - Tipicamente esiste una DF per ogni applicazione





Standard ISO7816

- Definisce le proprietà fisiche richieste ad una smartcard
 - ☐ Immune ai raggi UV
 - ☐ Impenetrabile a meno di provocare la distruzione dei componenti
 - ☐ Non influenzabile dall'ambiente nelle sue operazioni interne
 - ☐ ...



La realtà

- La protezione fisica dei dati è solo un mito
 - Dump dell'intera EEPROM
 - Alterazione di dati sensibili
 - Reverse-engineering di programmi e processori
 - Clonazione
 - ...
- Violazioni di carte per pay-TV e similia



Tassonomia di (classi di) attacchi

1. Invasivi

1.1 Microprobing – accedere e manipolare il chip

2. Non invasivi

2.1 Software attacks – sfruttare vulnerabilità di protocolli e algoritmi

2.2 Eavesdropping – monitorare radiazioni elettromagnetiche di linee alimentazione e dati

2.3 Fault induction – adoperare il chip in condizioni anormali



Invasivi vs. non invasivi

- Scopo comune: dump della memoria
- Contrariamente ai non invasivi, gli invasivi
 - Distruggono la smartcard
 - Non richiedono conoscenza approfondita H/SW
- Non invasivi più subdoli?
- Strategia tipica
 - Prima invasivi in laboratorio
 - Poi non invasivi in serie



1.1 Microprobing

- I. Estrazione del chip
- II. Riambientazione del chip
- III. Ricostruzione del disegno
- IV. Alterazioni manuali (microprobing vero e proprio)
- V. Lettura della memoria



I. Estrazione del chip

- a. Riscaldamento e separazione
- b. Bagno in acido nitrico a 60°
- c. Bagno in acetone e bombardamento ad ultrasuoni
- d. Bagno in acqua distillata e isopropanolo
- e. Rimozione dei collegamenti elettrici con micro tenaglie

I. Estrazione del chip

— fase a



I. Estrazione del chip

— fase b



I. Estrazione del chip

— fase c



I. Estrazione del chip

— fase d

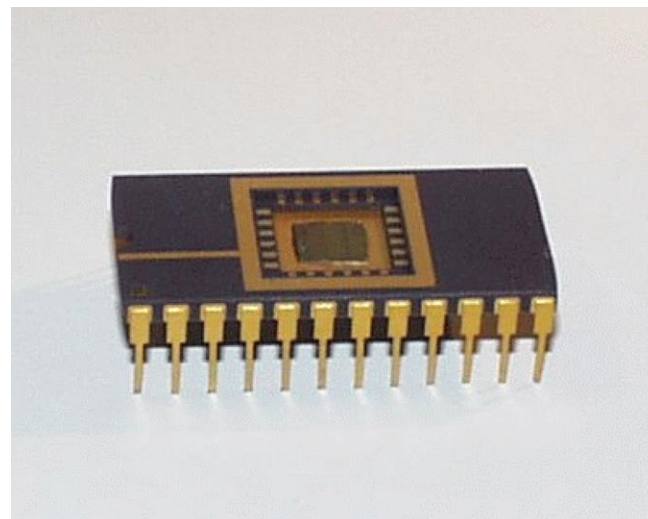
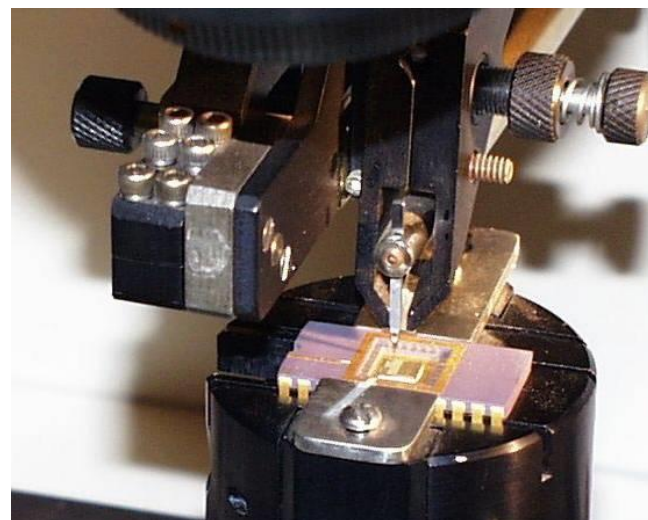




II. Riambientazione del chip

Usare una stazione d'assemblaggio manuale di circuiti per collegare mediante ultrasuoni

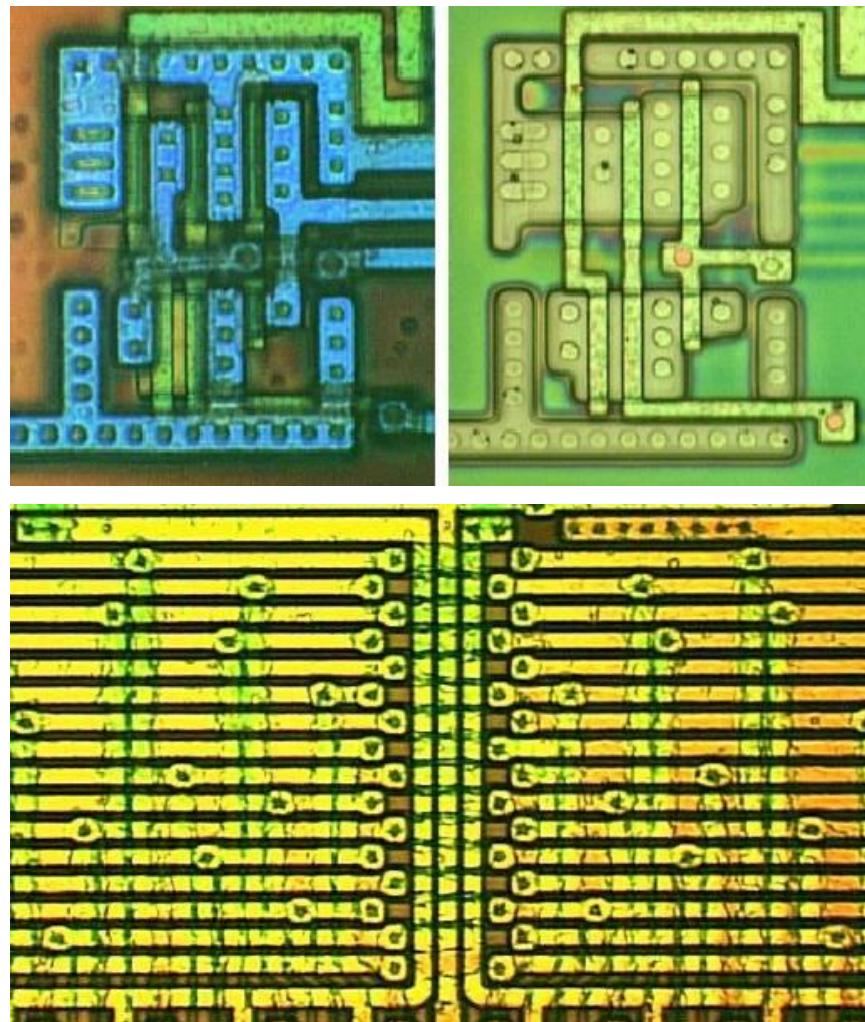
- a. contact plate a fili di alluminio
- b. questi a un chip ospite





III. Ricostruzione del disegno

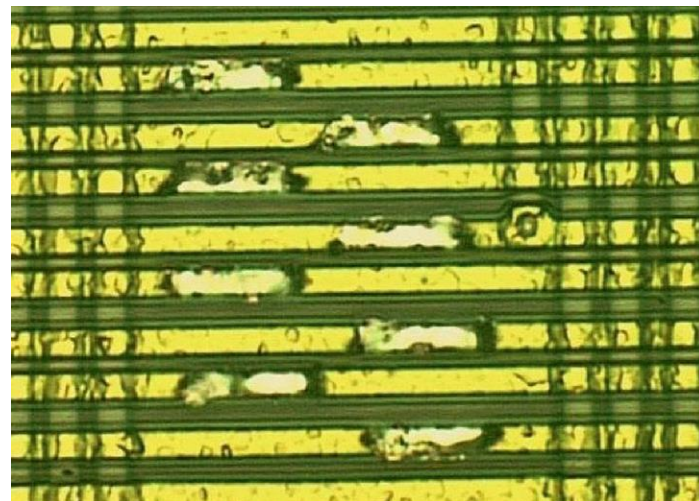
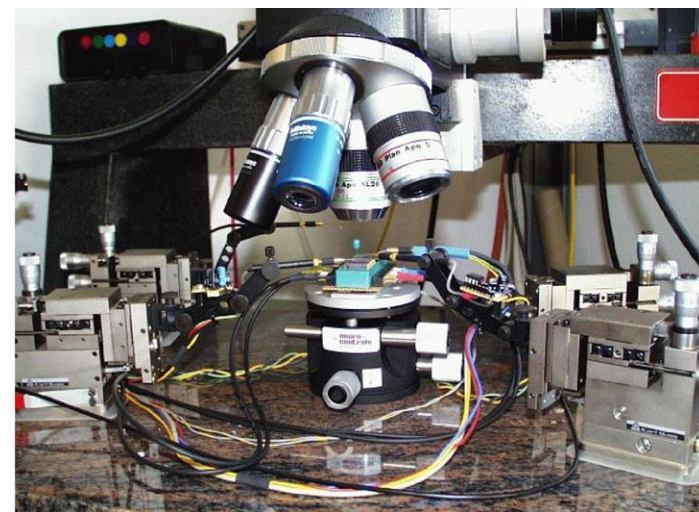
- Usare (vari tipi di) microscopi ottici collegati a macchine fotografiche per ricostruire disegno
- Competenza di circuiti VLSI





IV. Alterazioni manuali

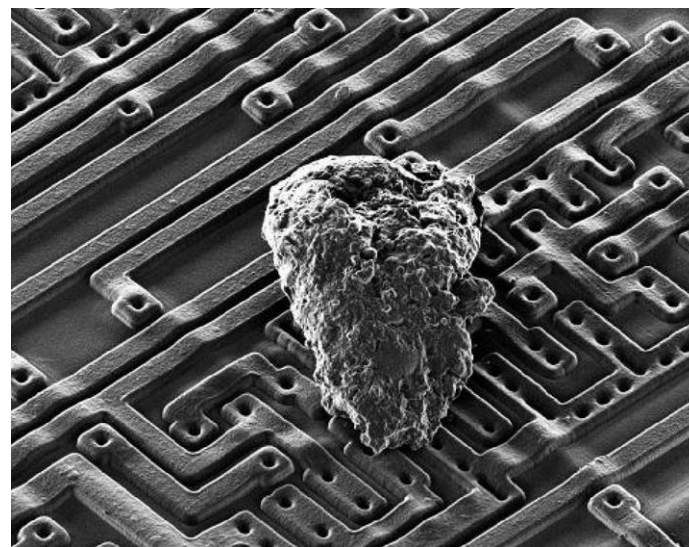
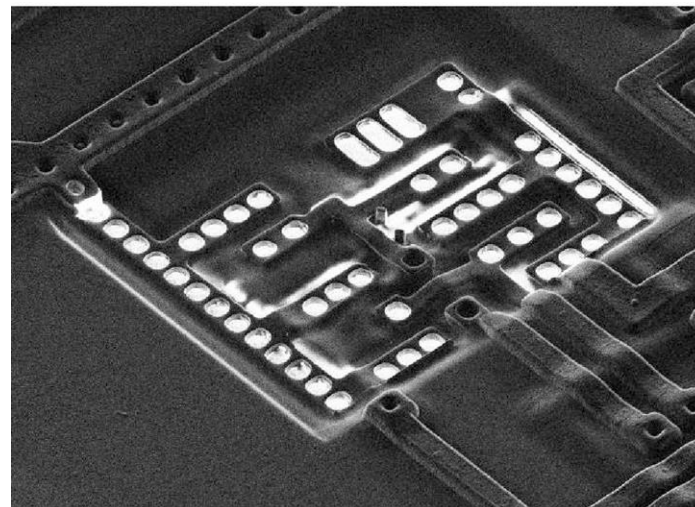
- Stazione di microprobing
 1. Speciale microscopio
 2. Probe: filo tungsteno $< .1\mu\text{m}$
 3. Microposizionatori per collegare probi
 4. Amplificatore di segnale
- Qualunque alterazione elettrica possibile
- 10000\$ seconda mano





IV. Alterazioni manuali

- Il bombardamento ionico è un'alternativa a probi e microposizionatori
- Permette rimozione e impianto ad alta precisione di materiale isolante o conduttore





V. Lettura della memoria

- Ogni cella di ROM con tecniche ottiche
 - Lungo e tedioso
- Il resto attraverso probi su linee dati
 - Ripetere una computazione shiftando 2-4 probi
- Vorremmo che il processore richiedesse accesso a tutte le celle con dati critici
 - Fortuna/sfortuna
 - Modificare il Program Counter



V. Lettura della memoria

- Accesso a tutte le celle con dati critici
 - Fortuna: checksum della memoria al reset
 - Sfortuna: accesso attivato da un messaggio firmato dal gestore del servizio
 - *Bancomat, pay-TV, ...*
- Modificare il PC eliminando salti e return
 - Si ottiene il dump dell'intera memoria



Tassonomia di (classi di) attacchi

1. Invasivi

1.1 Microprobing – accedere e manipolare il chip

2. Non invasivi

2.1 Software attacks – sfruttare vulnerabilità di protocolli e algoritmi

2.2 Eavesdropping – monitorare radiazioni elettromagnetiche di linee alimentazione e dati

2.3 Fault induction – adoperare il chip in condizioni anormali



2.1 Software attacks

■ Esempio I: sistemi di pay-TV

- Il decoder estrae la chiave da una smartcard e la usa per decodificare il segnale
- Se il cliente non paga l'abbonamento, il gestore del servizio manda l'ordine al decoder di disabilitare la smartcard
- Basta modificare il microcontrollore del decoder onde ignorare tali messaggi



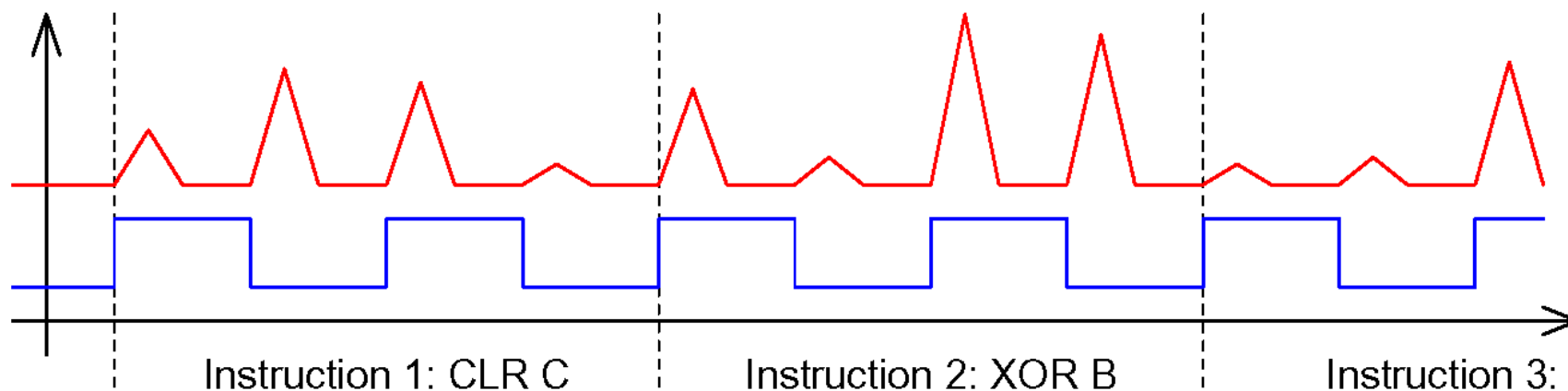
2.1 Software attacks

- Esempio II: modulo di sicurezza di banca
 - PIN funzione del numero di conto
 - Cambio formato numeri di conto cambia PIN
 - Per mantenere lo stesso PIN, una banca installa un modulo che calcola gli offset
 - Da rimuovere dopo aver prodotto tutti gli offset
 - Rimane la query: dato un numero di conto e il suo offset, trovare l'offset che fa funzionare il suo PIN su un altro conto



2.2 Eavesdropping

- Monitorare consumo di corrente sulle linee di alimentazione per riconoscere andamenti tipici indotti dalle istruzioni
- Rischi di covert channel





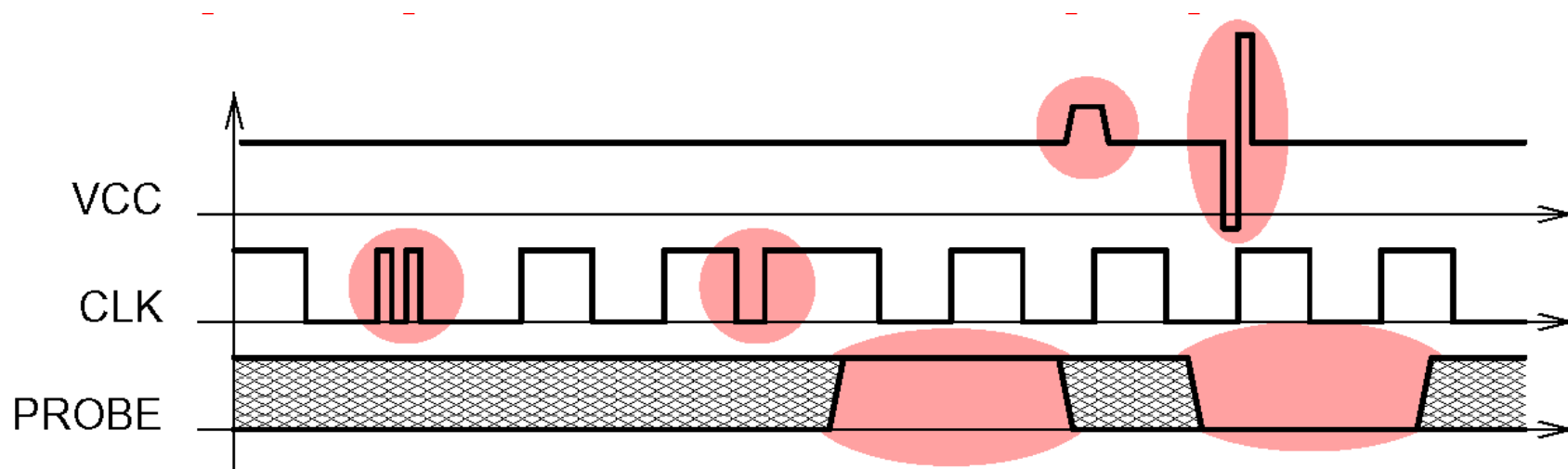
2.3 Fault induction

- Un attaccante può indurre flip di bit
 - Le caratteristiche analogiche del chip sono sensibili ad influenze esterne
 - *Elettromagnetiche, termiche, UV, ...*
 - Il chip è interamente controllabile dall'esterno
 - Linee di alimentazione e clock
- Per ottenere l'effetto sono necessari numerosi esperimenti di **analisi differenziale**



Analisi differenziale

- Verificare i risultati in seguito a **glitch**,
ossia alterazioni sulla linea di
 - ☐ Alimentazione
 - ☐ Clock





Esempi

- Glitch di corrente espongono la memoria in PIC16C84, DS5000, ...
- Glitch di corrente compromettono il random number generator

```
1  b = answer_address
2  a = answer_length
3  if (a == 0) goto 8
4  transmit(*b)
5  b = b + 1
6  a = a - 1
7  goto 3
8  ...
```



Contromisure

- Segnale di clock randomizzato
- Processore multithread
- Sensore di bassa frequenza
- Irrobustimento del Program Counter
- ...



Chip and pin helps push bank and credit card fraud to £505m

Miles Brignall, Tuesday March 8, 2005

[The Guardian](#)

Bank and credit card fraud rose 20% last year, costing British banks £505m, with part of the increase due to the introduction of new chip and pin cards. Apacs, the clearing payments association that compiled the figures on the banking industry's behalf, said the amount stolen using bank cards rose from £420.4m in 2003 to £504.8m in 2004. Fraud on cards stolen before the genuine cardholders receive them grew sharply - up 62% to £72.9m - as criminals took advantage of the unusually high number of cards sent out due to the rollout of new chip and pin cards. In 2004, 100,000 replacement cards were sent out each day. Overall, fraud at British cash machines grew 81% to £74.6m.

Card-not-present fraud - consumers buying goods over the internet and telephone - continues to be the biggest fraud type, rising 24% last year to £150.8m. Apacs said online credit card payments have increased five-fold since 1999, reaching 10% of all credit card spending. Thefts using skimmed or cloned cards - favoured by criminal gangs - rose 17% to £129m last year, while the amount bought using lost and stolen cards rose just 2% to £114.4m.

Despite a number of recent scare stories, Apacs said identity theft remains a small proportion of overall fraud. It rose 22% to £36.9m in 2004. Sandra Quinn, director of corporate communications at Apacs, said: "When the banking industry decided to introduce chip and pin in the UK our fraud forecasts showed that without it card fraud losses would top £800m by 2005. "So while we still have a battle on our hands, we are on track to see a significant reduction in this amount." For the first time, Apacs has calculated total losses for online banking fraud, which it said reached £12m in 2004. Fraud loss overseas was the only area to fall - down 11% to £92.5m. • **More than £16m was paid out last year in rewards to shop staff who retained cards they suspected were stolen.**



Approfondimenti

- Materiale dalla pagina di Markus Kuhn
- Costi min/max di una smartcard di oggi
- Investigare APDU (Application Protocol Data Unit)
- Approfondire Javacard (applet di OpenSSH)
- Provare fault induction su una smartcard...